密级：内部

文档编号：HYKY-PPD-SDD-001

项目名称：基于 Agent 的智能康养系统

项目编号：HYKY-2026

海屿康养社区概要设计

版本：1.0.0

2026 年 9 月 19 日

大连理工大学软件学院实习实训项目

基于审核通过文档结构修订

1 文件修改控制

修改编号	版本	修改内容及原因	修改日期
1	0.1.0	形成海屿康养社区概要设计初稿	2026-09-18
2	1.0.0	参照审核通过的概要设计，补全模块图、流程、数据库字段、详细接口和 Agent 安全设计	2026-09-19

2 目录

1 文档概述

1.1 文档目的和范围

1.2 术语和缩略语

1.3 参考文档

1.4 设计原则和实现边界

2 系统结构图

2.1 系统上下文

2.2 总体技术架构

2.3 部署架构

2.4 角色权限矩阵

3 模块详细概述

3.1 公开服务与身份入口模块

3.2 登录鉴权与个人账号模块

3.3 客人档案模块

3.4 健康记录与医嘱模块

3.5 工作人员业务模块

3.6 院长管理模块

3.7 Agent 智能协作模块

3.8 审计与安全模块

4 数据库设计

4.1 数据库引擎概述

4.2 数据库概念设计

4.3 数据表详细设计

4.4 索引 约束与数据生命周期

5 接口设计

5.1 全局约定

5.2 接口清单

5.3 关键接口函数详细设计

5.4 关键数据结构说明

6 非功能设计

6.1 安全与隐私

6.2 性能与可靠性

6.3 可维护性与可测试性

6.4 部署与运维

7 当前完成度与后续计划

3 1 文档概述

3.1 1.1 文档目的和范围

本文档给出海屿康养社区智能康养系统的概要设计，为后续详细设计、编码、测试、部署和项目评审提供统一依据。文档覆盖公开服务门户、客人个人空间、工作人员工作台、院长管理、Agent 智能协作、身份认证、审计和数据持久化等部分。

系统服务于康养社区场景，核心目标是在保护个人健康信息的前提下，连接客人、工作人员和管理人员。Agent 作为业务辅助入口，负责自然语言接待、健康信息引导采集、工作记录整理和管理分析，不直接作出医疗诊断，也不自动发布医嘱。

3.2 1.2 术语和缩略语

序号	术语	说明
1	API	应用程序接口，前后端以 JSON 格式交换数据
2	Agent	面向特定角色和任务的智能助手
3	LLM	大语言模型，可通过兼容接口接入本系统
4	RBAC	基于角色的访问控制
5	JWT-like Token	当前原型使用 HMAC 签名的轻量令牌，生产环境可替换标准 JWT/OIDC
6	DTO	数据传输对象，用于描述接口输入
7	VO	视图对象，用于描述接口输出
8	P95	95% 请求的响应时间上界
9	人工确认边界	AI 生成内容在产生业务影响前必须由授权人员核对确认

3.3 1.3 参考文档

序号	文档名	来源	版本/日期
1	概要设计 demo.doc	审核通过的概要设计参考	2025-11-27
2	概要设计模板.doc	项目文档模板	0.8.0

序号	文档名	来源	版本/日期
3	海屿康养社区源代码	项目工作区	2026-09-19
4	实习实训项目计划	课程项目要求	2026 年
5	模型服务接口文档	实际选定服务商	接入时确认

3.4 1.4 设计原则和实现边界

原则	概要设计要求
角色隔离	公开页面不显示个人信息；guest、staff、dean 仅访问各自授权资源
最小权限	工作人员仅查看履职所需字段；院长查看管理所需的工作记录
双端约束	只读字段既在界面灰度禁用，也必须在后端使用字段白名单拒绝修改
可追溯	登录、查看档案、发布建议、院长评价、Agent 健康采集均记录日志
Agent 可用而不越权	可接真实模型；未配置时明确显示安全引导模式；不诊断、不自动发布医嘱
分阶段建设	当前为可运行 MVP；上线前完成正式数据库、HTTPS、备份、风控评测和账号治理

4 2 系统结构图

4.1 2.1 系统上下文

系统外部参与者包括访客、客人、工作人员、院长和模型服务。访客只访问公开内容；客人访问本人数据；工作人员访问其职责范围内的客人；院长访问团队工作记录；模型服务仅接收后端筛选后的必要上下文。

4.2 2.2 总体技术架构

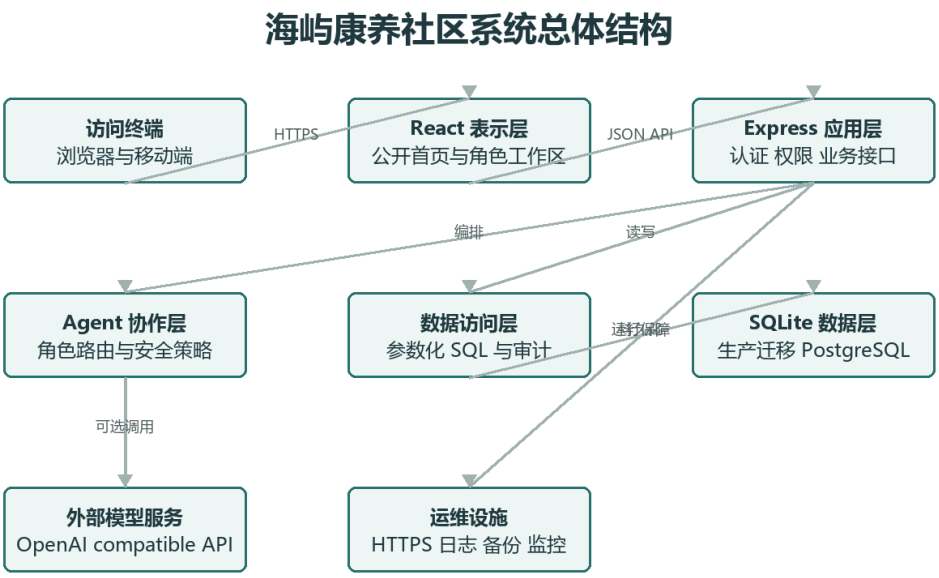


图 2-1 系统总体结构图

层次	主要技术	职责	当前状态
表示层	React 18、Vite 5	页面路由、表单、悬浮 Agent、状态反馈	已实现
应用层	Node.js、Express	REST API、认证授权、业务校验	已实现 MVP
智能协作层	角色提示词、规则降级、LLM Adapter	上下文装配、推理、安全提示	已实现接口与降级
数据层	node:sqlite、SQLite WAL	业务数据、审计、对话持久化	已实现演示库
生产基础设施	Nginx、容器、PostgreSQL、监控	HTTPS、扩展、备份、告警	待上线阶段完成

4.3 2.3 部署架构

开发环境由 Vite 开发服务器监听 5180 端口，Express API 监听 3020 端口，前端通过 /api 代理访问后端。生产环境建议将前端静态资源部署到 Nginx，API 以容器或进程管理器运行，数据库独立部署并启用备份。LLM_API_KEY 只存在服务端密钥管理系统中。

4.4 2.4 角色权限矩阵

资源/操作	访客	客人	工作人员	院长

资源/操作	访客	客人	工作人员	院长
公开新闻	查看	查看	查看	查看
本人档案	不可	查看/有限修改	按授权查看	按管理授权查看
健康记录	不可	查看本人	查看授权客人	汇总查看
医嘱建议	不可	查看本人	创建授权客人建议	查看与监督
工作人员日志	不可	不可	查看本人摘要	查看团队
院长意见	不可	不可	查看本人相关	创建/查看
Agent	公开接待	健康支持	工作辅助	管理辅助

5　3 模块详细概述

本章按照审核参考文档的模块颗粒度，逐一说明功能定义、模块结构、处理流程和接口。各模块通过 REST API 交互，前端不直接访问数据库或模型服务。

5.1 3.1 公开服务与身份入口模块

该模块是系统公共入口，负责展示社区动态、服务说明、演示天气和角色入口，严格避免在未登录页面展示个人资料。

5.1.1 3.1.1 公开服务与身份入口模块功能定义

序号	功能点	功能点详细说明
1	社区动态	加载置顶与普通新闻，支持阅读全文弹窗
2	天气演示	从预置数据中随机切换，用于界面展示
3	身份入口	进入客人或工作人员登录页面
4	公开接待 Agent	回答服务范围和入口问题，不收集高敏感信息

5.1.2 3.1.2 公开服务与身份入口模块模块结构

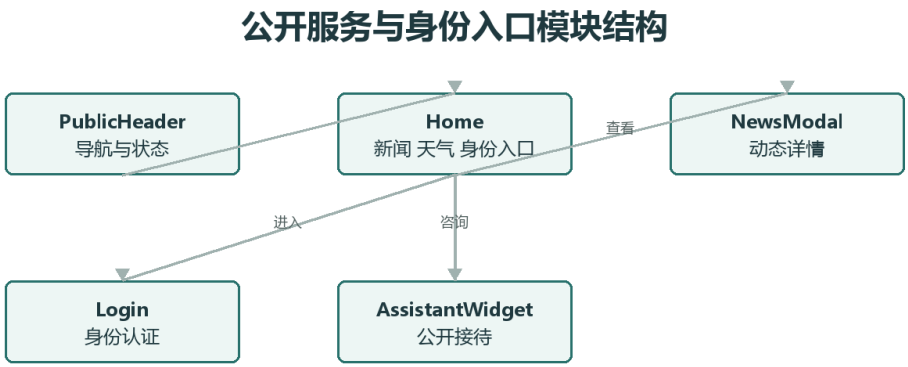


图 3-1 公开服务与身份入口模块模块结构图

5.1.3 3.1.3 公开服务与身份入口模块处理流程

用户进入首页后可浏览新闻和服务说明。点击身份入口转入登录页；点击悬浮助手进入 public 会话。新闻加载失败时显示空状态，不影响身份入口。

5.1.4 3.1.4 公开服务与身份入口模块接口说明

序号	模块	接口	函数/处理说明
1	公开服务与身份入口模块	GET /api/news	查询公开新闻列表
2	公开服务与身份入口模块	GET /api/news/:id	查询单条新闻
3	公开服务与身份入口模块	GET /api/assistant/status	查询 Agent 服务状态
4	公开服务与身份入口模块	POST /api/assistant/chat	发起公开接待对话

设计注意事项：天气数据仅用于演示，必须标注或避免被理解为实时气象信息。

5.2 3.2 登录鉴权与个人账号模块

该模块负责账号、密码、身份一致性校验，签发有时效的访问令牌，并提供密码修改。

5.2.1 3.2.1 登录鉴权与个人账号模块功能定义

序号	功能点	功能点详细说明
1	身份登录	用户名、密码和角色三项共同校验
2	令牌鉴权	验证签名、过期时间和账号 active 状态
3	角色授权	根据 guest/staff/dean 限制接口
4	密码修改	验证旧密码，新密码不少于 8 位并重新哈希
5	退出登录	客户端清除令牌和用户缓存

5.2.2 3.2.2 登录鉴权与个人账号模块模块结构



图 3-2 登录鉴权与个人账号模块模块结构图

5.2.3 3.2.3 登录鉴权与个人账号模块处理流程

登录成功后签发 8 小时有效的 HMAC 令牌。每次受保护请求重新查询账号状态，防止停用账号继续访问。

5.2.4 3.2.4 登录鉴权与个人账号模块接口说明

序号	模块	接口	函数/处理说明
1	登录鉴权与个人账号模块	POST /api/auth/login	登录并返回 token 与安全用户对象
2	登录鉴权与个人账号模块	GET /api/me	返回当前用户工作区数据
3	登录鉴权与个人账号模块	POST /api/me/password	修改当前账号密码

设计注意事项：上线前必须替换 AUTH_SECRET，建议引入刷新令牌、登录失败限流和强密码策略。

5.3 3.3 客人档案模块

客人档案区分可编辑联系信息和机构维护字段。只读字段在页面禁用，后端以白名单方式拒绝非授权字段。

5.3.1 3.3.1 客人档案模块功能定义

序号	功能点	功能点详细说明
1	资料查看	展示姓名、性别、出生日期、房间、入住信息、慢病、过敏等
2	有限修改	仅允许电话、紧急联系人、行动能力等规定字段
3	只读灰度	身份、入住和健康标签显示锁定状态
4	数据校验	限制长度、格式并过滤多余字段
5	修改审计	保存操作人、资源和时间

5.3.2 3.3.2 客人档案模块模块结构



图 3-3 客人档案模块模块结构图

5.3.3 3.3.3 客人档案模块处理流程

进入个人资料时加载本人档案。保存时前端仅发送可编辑字段，后端再次按 allowlist 提取字段；如携带性别、出生日期、房间等字段则忽略或返回 400。

5.3.4 3.3.4 客人档案模块接口说明

序号	模块	接口	函数/处理说明
1	客人档案模块	GET /api/me	读取本人档案和摘要
2	客人档案模块	PATCH /api/me/profile	修改允许字段并写入审计

设计注意事项：当前原型的后端字段白名单仍需进一步收紧，这是上线前必须完成的实现整改项。

5.4 3.4 健康记录与医嘱模块

该模块向客人展示健康记录和有效医嘱，向授权工作人员提供客人健康摘要，并保留建议作者与时间。

5.4.1 3.4.1 健康记录与医嘱模块功能定义

序号	功能点	功能点详细说明
1	健康记录查看	按记录时间倒序展示指标、数值、单位和备注

序号	功能点	功能点详细说明
2	医嘱查看	展示标题、内容、优先级、状态和作者
3	建议发布	工作人员输入标题、正文和重要程度
4	风险提示	urgent 内容在界面突出显示
5	状态追溯	保留 created_at、updated_at 和 author_id

5.4.2 3.4.2 健康记录与医嘱模块模块结构



图 3-4 健康记录与医嘱模块模块结构图

5.4.3 3.4.3 健康记录与医嘱模块处理流程

客人只能查询本人记录。工作人员从客人详情进入，后端先验证角色和客人存在性；发布建议必须经过人工确认，成功后写入 medical_advice 与 audit_logs。

5.4.4 3.4.4 健康记录与医嘱模块接口说明

序号	模块	接口	函数/处理说明
1	健康记录与医嘱模块	GET /api/me/health	读取健康记录
2	健康记录与医嘱模块	GET /api/me/advice	读取医嘱建议
3	健康记录与医嘱模块	POST /api/staff/guests/:id/advice	发布医嘱或建议

设计注意事项：目前工作人员与客人的具体分配关系尚未建表，生产设计应增加 staff_guest_assignments 并据此授权。

5.5 3.5 工作人员业务模块

工作人员工作台负责工作概览、客人检索、档案查看、健康信息查看与建议发布。

5.5.1 3.5.1 工作人员业务模块功能定义

序号	功能点	功能点详细说明
1	工作概览	展示客人数量、有效医嘱和近期工作
2	客人搜索	按姓名或房间号模糊查询
3	客人详情	查看必要的档案、健康记录和医嘱
4	建议发布	人工填写或核对 Agent 草稿后发布
5	工作留痕	查看档案和发布建议均形成审计记录

5.5.2 3.5.2 工作人员业务模块模块结构



图 3-5 工作人员业务模块模块结构图

5.5.3 3.5.3 工作人员业务模块处理流程

工作人员登录后进入工作台，通过搜索选择客人。查看详情时后端记录 guest.view；发布建议前工作人员确认客人、标题、内容和优先级。

5.5.4 3.5.4 工作人员业务模块接口说明

序号	模块	接口	函数/处理说明
1	工作人员业务模块	GET /api/staff/overview	获取工作概览
2	工作人员业务模块	GET /api/staff/guests	查询客人列表
3	工作人员业务模块	GET /api/staff/guests/:id	查询客人详情
4	工作人员业务模块	POST /api/staff/guests/:id/advice	发布建议

设计注意事项：目标设计要求按负责关系过滤客人；当前 MVP 为演示方便返回所有 active 客人，应作为权限整改重点。

5.6 3.6 院长管理模块

院长模块用于查看工作人员的工作记录和建议数量，并记录管理意见。

5.6.1 3.6.1 院长管理模块功能定义

序号	功能点	功能点详细说明
1	人员列表	展示工作人员账号、状态和工作量摘要
2	工作日志	查看指定工作人员最近 50 条审计记录
3	意见记录	对工作人员写入指导意见
4	管理辅助	Agent 汇总已授权记录中的问题和改进方向

5.6.2 3.6.2 院长管理模块模块结构

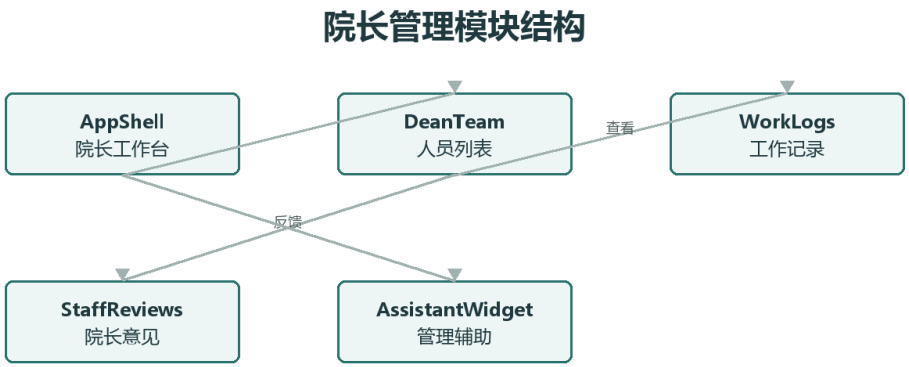


图 3-6 院长管理模块模块结构图

5.6.3 3.6.3 院长管理模块处理流程

院长选择工作人员后读取其日志和本人创建的评价；提交意见时验证目标工作人员和内容非空，并写入 staff_reviews 与 audit_logs。

5.6.4 3.6.4 院长管理模块接口说明

序号	模块	接口	函数/处理说明
1	院长管理模块	GET /api/dean/staff	读取工作人员列表
2	院长管理模块	GET /api/dean/staff/:id/logs	读取工作记录与评价
3	院长管理模块	POST /api/dean/staff/:id/reviews	新增院长意见

设计注意事项：院长意见属于管理记录，应设置留存期限、访问审计和更正流程。

5.7 3.7 Agent 智能协作模块

Agent 以悬浮对话窗口存在，根据页面和登录角色切换 public、guest、staff、dean 四种能力。

5.7.1 3.7.1 Agent 智能协作模块功能定义

序号	功能点	功能点详细说明

序号	功能点	功能点详细说明
1	角色路由	根据认证身份选择系统提示词
2	会话管理	sessionId 串联消息并加载最近 12 条历史
3	上下文装配	按授权加载本人或指定客人摘要
4	模型调用	调用 OpenAI-compatible /chat/completions
5	安全降级	未配置或模型异常时返回规则引导
6	健康采集	识别慢病、用药、过敏、睡眠等输入并写入 health_intakes
7	人工确认	工作人员 Agent 只生成草稿，不自动发布医嘱

5.7.2 3.7.2 Agent 智能协作模块模块结构



图 3-7 Agent 智能协作模块模块结构图

5.7.3 3.7.3 Agent 智能协作模块处理流程

处理流程如图所示。匿名请求强制为 public；登录用户请求角色必须与令牌角色一致。服务端拼装最小必要上下文，模型输出经边界提示后返回，同时保存用户消息和助手消息。

5.7.4 3.7.4 Agent 智能协作模块接口说明

序号	模块	接口	函数/处理说明

序号	模块	接口	函数/处理说明
1	Agent 智能协作模块	GET /api/assistant/status	返回 live、model、provider 和 fallback
2	Agent 智能协作模块	POST /api/assistant/chat	处理角色对话并返回 sessionId、reply、quickReplies、mode
3	Agent 智能协作模块	GET /api/agent/status	返回可解释的多 Agent 协作状态

设计注意事项：生产环境还需实现输入输出内容安全检测、敏感字段脱敏、速率限制、模型调用审计和质量评测。

5.8 3.8 审计与安全模块

该模块记录关键操作并统一处理鉴权失败、越权、资源不存在和服务器异常。

5.8.1 3.8.1 审计与安全模块功能定义

序号	功能点	功能点详细说明
1	审计写入	记录 actor、action、target、detail 和时间
2	异常响应	使用 400/401/403/404/500/502 状态码
3	隐私最小化	接口只返回页面所需字段
4	输入限制	JSON 请求体上限 256 KB
5	密钥隔离	模型密钥和认证密钥只在服务端环境变量

5.8.2 3.8.2 审计与安全模块模块结构



图 3-8 审计与安全模块模块结构图

5.8.3 3.8.3 审计与安全模块处理流程

请求先经过解析和鉴权中间件，再进入业务处理；关键成功操作写审计。异常统一返回中文错误信息，不向前端泄露堆栈、SQL 或密钥。

5.8.4 3.8.4 审计与安全模块接口说明

序号	模块	接口	函数/处理说明
1	审计与安全模块	auth middleware	验证 Bearer Token 和账号状态
2	审计与安全模块	staffOnly middleware	允许 staff/dean
3	审计与安全模块	deanOnly middleware	仅允许 dean
4	审计与安全模块	log()	写入 audit_logs

设计注意事项：日志 detail 不应存储完整病历或模型密钥，生产环境应加入脱敏和独立安全日志。

6 4 数据库设计

6.1 4.1 数据库引擎概述

当前使用 Node.js 内置 node:sqlite 连接 SQLite，启用 WAL 和外键约束，数据文件默认为

server/data/community-v2.sqlite。该选择适合课程演示与单机 MVP。生产环境建议迁移 PostgreSQL，使用迁移工具、连接池、主从备份和最小权限数据库账号。

6.2 4.2 数据库概念设计

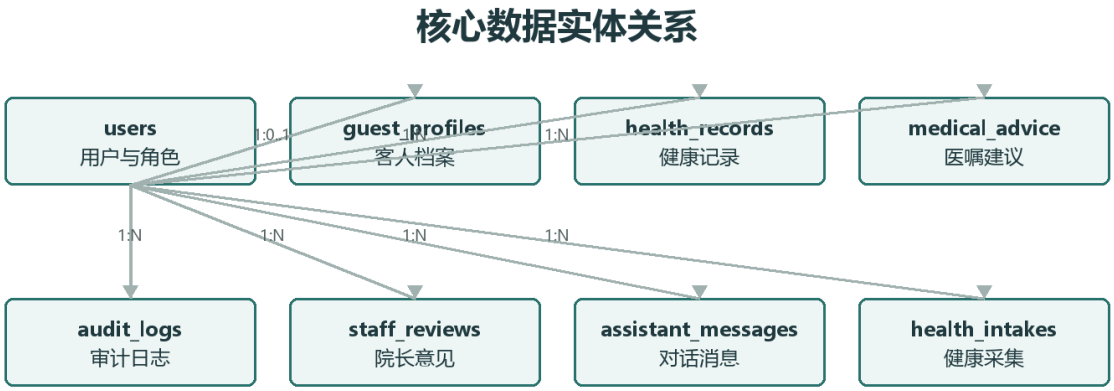


图 4-1 核心数据实体关系图

users 是统一身份主表；guest_profiles 以 user_id 与客人一对一；健康记录、医嘱、审计日志、院长意见、Agent 消息和健康采集均通过用户或会话建立关联。新闻表独立服务公开首页。

6.3 4.3 数据表详细设计

6.3.1 users 用户表

字段	类型	约束	说明
id	TEXT	PK	用户唯一标识
username	TEXT	UNIQUE NOT NULL	登录名
password_hash	TEXT	NOT NULL	scrypt 盐值和摘要
role	TEXT	CHECK	guest/staff/dean
name	TEXT	NOT NULL	姓名
phone	TEXT		联系电话
avatar	TEXT		头像地址

字段	类型	约束	说明
status	TEXT	DEFAULT active	账号状态
created_at	TEXT	NOT NULL	创建时间

6.3.2 guest_profiles 客人档案表

字段	类型	约束	说明
user_id	TEXT	PK FK	关联 users
gender	TEXT		性别，只读登记
birth_date	TEXT		出生日期
room_no	TEXT		房间号
check_in	TEXT		入住日期
check_out	TEXT		离店日期
emergency_contact	TEXT		紧急联系人
chronic_json	TEXT	NOT NULL	慢病数组 JSON
allergies_json	TEXT	NOT NULL	过敏数组 JSON
mobility	TEXT		行动能力
updated_at	TEXT	NOT NULL	更新时间

6.3.3 health_records 健康记录表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	记录编号
guest_id	TEXT	FK NOT NULL	客人编号
record_type	TEXT	NOT NULL	指标类型
value	TEXT	NOT NULL	测量值
unit	TEXT		单位
note	TEXT		备注

字段	类型	约束	说明
recorded_at	TEXT	NOT NULL	记录时间
recorded_by	TEXT	NOT NULL	记录人员编号

6.3.4 medical_advice 医嘱建议表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	建议编号
guest_id	TEXT	FK NOT NULL	客人编号
author_id	TEXT	FK NOT NULL	作者编号
title	TEXT	NOT NULL	标题
content	TEXT	NOT NULL	正文
priority	TEXT	CHECK	normal/important/urgent
status	TEXT	CHECK	active/closed
created_at	TEXT	NOT NULL	创建时间
updated_at	TEXT	NOT NULL	更新时间

6.3.5 news 新闻表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	新闻编号
category	TEXT	NOT NULL	分类
title	TEXT	NOT NULL	标题
summary	TEXT	NOT NULL	摘要
body	TEXT	NOT NULL	正文
cover	TEXT		封面
published_at	TEXT	NOT NULL	发布时间
pinned	INTEGER	DEFAULT 0	是否置顶

6.3.6 audit_logs 审计日志表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	日志编号
actor_id	TEXT		操作人
action	TEXT	NOT NULL	动作编码
target_type	TEXT		资源类型
target_id	TEXT		资源编号
detail	TEXT		脱敏说明
created_at	TEXT	NOT NULL	操作时间

6.3.7 staff_reviews 院长意见表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	意见编号
staff_id	TEXT	FK NOT NULL	工作人员
dean_id	TEXT	FK NOT NULL	院长
content	TEXT	NOT NULL	意见内容
created_at	TEXT	NOT NULL	创建时间

6.3.8 assistant_messages Agent 消息表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	消息编号
session_id	TEXT	NOT NULL	会话编号
user_id	TEXT		用户编号，公开会话可空
role	TEXT	CHECK	user/assistant

字段	类型	约束	说明
content	TEXT	NOT NULL	消息正文
created_at	TEXT	NOT NULL	创建时间

6.3.9 health_intakes 健康采集表

字段	类型	约束	说明
id	INTEGER	PK AUTOINCREMENT	采集编号
guest_id	TEXT	FK NOT NULL	客人编号
content	TEXT	NOT NULL	客人原始描述
source	TEXT	DEFAULT assistant	来源
created_at	TEXT	NOT NULL	创建时间

6.4 4.4 索引 约束与数据生命周期

类别	设计要求
索引	users.username 唯一索引；health_records(guest_id, recorded_at)；medical_advice(guest_id, status, created_at)；audit_logs(actor_id, created_at)；assistant_messages(session_id, id)
外键	客人档案、健康记录、医嘱、评价和采集表必须启用外键；删除用户时按业务规则限制或级联
事务	发布医嘱与写审计、修改档案与写审计应在同一事务完成
备份	生产数据库每日增量、每周全量，定期执行恢复演练
留存	健康数据、Agent 原始消息和审计日志分别制定留存期限；到期匿名化或安全删除
迁移	使用版本化 SQL migration，禁止直接修改生产表结构

7 5 接口设计

7.1 5.1 全局约定

项目	约定
基础路径	/api
数据格式	application/json; charset=utf-8
认证方式	Authorization: Bearer <token>
时间格式	ISO 8601 UTC，前端按 Asia/Shanghai 展示
成功响应	200 查询成功；201 创建成功
错误响应	400 参数错误；401 未认证；403 无权限；404 不存在；500 内部错误；502 模型服务失败
请求限制	JSON 请求体不超过 256 KB；生产环境增加频率限制
幂等性	GET 幂等；创建类 POST 生产环境建议支持 Idempotency-Key

7.2 5.2 接口清单

序号	方法	路径	功能	权限
1	GET	/api/health	服务健康检查	公开
2	GET	/api/news	新闻列表	公开
3	GET	/api/news/:id	新闻详情	公开
4	POST	/api/auth/login	登录	公开
5	GET	/api/me	当前用户信息	登录
6	PATCH	/api/me/profile	修改客人可编辑资料	guest
7	POST	/api/me/password	修改密码	登录
8	GET	/api/me/health	健康记录	guest/staff/dean
9	GET	/api/me/advice	医嘱列表	guest/staff/dean
10	GET	/api/staff/overview	工作概览	staff/dean
11	GET	/api/staff/guests	查询客人	staff/dean

序号	方法	路径	功能	权限
12	GET	/api/staff/guests/:id	客人详情	staff/dean
13	POST	/api/staff/guests/:id/advice	发布建议	staff/dean
14	GET	/api/dean/staff	工作人员列表	dean
15	GET	/api/dean/staff/:id/logs	工作日志	dean
16	POST	/api/dean/staff/:id/reviews	院长意见	dean
17	GET	/api/assistant/status	Agent 状态	公开
18	POST	/api/assistant/chat	Agent 对话	公开/登录
19	GET	/api/agent/status	协作状态	登录

7.3 5.3 关键接口函数详细设计

7.3.1 5.3.1 login

函数名	login			
文件名	server/src/index.js			
功能概要	用户登录认证			
参数	类型	变量名	I/O	说明
	username	string	IN	账号

	password	string	IN	密码
	role	enum	IN	guest/staff/dean
返回值	LoginVO			
详细说明	校验账号、角色、active 状态和密码哈希，记录 login 审计，签发 8 小时令牌。			
使用注意事项	失败统一返回 401，不区分账号不存在或密码错误。			

7.3.2 5.3.2 getMe

函数名	getMe
文件名	server/src/index.js
功能概要	读取当前用户工作区数据

参数	类型	变量名	I/O	说明
	Authorization	string	IN	Bearer Token
返回值	UserWorkspaceVO			
详细说明	客人返回档案、健康和医嘱摘要；工作人员返回基本信息和统计。			
使用注意事项	输出前移除 password_hash 等敏感字段。			

7.3.3 5.3.3 updateProfile

函数名	updateProfile
文件名	server/src/index.js
功能概要	修改客人可编辑资料

参数	类型	变量名	I/O	说明
	phone	string	IN	联系电话
	emergencyContact	string	IN	紧急联系人
	mobility	string	IN	行动能力
返回值	GuestSummaryVO			
详细说明	按字段白名单更新 users 和 guest_profiles，并写 profile.update 审计。			
使用注意事项	姓名、性别、出生日期、房间、入住信息、慢病和过敏不得由客人修改。			

7.3.4 5.3.4 changePassword

函数名	changePassword
文件名	server/src/index.js

功能概要	修改登录密码			
参数	类型	变量名	I/O	说明
	currentPassword	string	IN	当前密码
	newPassword	string	IN	新密码
返回值	ResultVO			
详细说明	验证旧密码，新密码至少 8 位，使用新随机盐进行 scrypt 哈希。			
使用注意事项	生产环境应增加复杂度、历史密码和频率限制。			

7.3.5 5.3.5 listGuests

函数名	listGuests

文件名	server/src/index.js			
功能概要	查询工作人员负责的客人			
参数	类型	变量名	I/O	说明
	q	string	IN	姓名或房间号
返回值	GuestListVO			
详细说明	按姓名或房间号模糊查询，并按负责关系过滤。			
使用注意事项	当前 MVP 尚未实现 staff_guest_assignments，生产前必须补齐。			

7.3.6 5.3.6 getGuestDetail

函数名	getGuestDetail			
文件名	server/src/index.js			
功能概要	读取客人档案详情			
参数	类型	变量名	I/O	说明
	id	string	IN	客人编号
返回值	GuestSummaryVO			
详细说明	校验角色、资源存在性和负责关系，返回必要字段并记录 guest.view。			
使用注意事项	不得返回无关客人的信息。			

7.3.7 5.3.7 createAdvice

函数名	createAdvice			
文件名	server/src/index.js			
功能概要	发布医嘱或建议			
参数	类型	变量名	I/O	说明
	id	string	IN	客人编号
	title	string	IN	标题
	content	string	IN	内容
	priority	enum	IN	优先级
返回值	ResultVO			
详细说明	校验字段和客人权限，写入 medical_advice，同时记录 advice.create。			

使用注意事项	Agent 草稿必须经工作人员人工确认。

7.3.8 5.3.8 listStaff

函数名	listStaff			
文件名	server/src/index.js			
功能概要	院长查询工作人员			
参数	类型	变量名	I/O	说明
	Authorization	string	IN	院长令牌
返回值	StaffListVO			
详细说明	查询 active/inactive 工作人员，并统计查看次数和建议数量。			

使用注意事项	仅 dean 可访问。

7.3.9 5.3.9 getStaffLogs

函数名	getStaffLogs			
文件名	server/src/index.js			
功能概要	院长查看工作日志			
参数	类型	变量名	I/O	说明
	id	string	IN	工作人员编号
返回值	StaffLogVO			

详细说明	返回最近 50 条日志和当前院长已写意见。
使用注意事项	日志 detail 必须脱敏。

7.3.10 5.3.10 createReview

函数名	createReview			
文件名	server/src/index.js			
功能概要	记录院长意见			
参数	类型	变量名	I/O	说明
	id	string	IN	工作人员编号
	content	string	IN	意见内容
返回值	ResultVO			

详细说明	验证人员和非空内容，写 staff_reviews 和 staff.review 审计。
使用注意事项	限制长度并防止脚本内容。

7.3.11 5.3.11 assistantStatus

函数名	assistantStatus			
文件名	server/src/assistant.js			
功能概要	获取 Agent 服务状态			
参数	类型	变量名	I/O	说明
	无	无	—	无参数

返回值	AssistantStatusVO
详细说明	依据 LLM_BASE_URL 和 LLM_API_KEY 判断 live，返回模型、提供商和降级模式。
使用注意事项	不得返回 API Key。

7.3.12 5.3.12 chatWithAssistant

函数名	chatWithAssistant			
文件名	server/src/assistant.js			
功能概要	处理 Agent 对话			
参数	类型	变量名	I/O	说明

	role	enum	IN	角色
	text	string	IN	用户文本
	sessionId	string	IN	会话编号
	guestId	string	IN	授权客人编号
返回值	AssistantChatVO			
详细说明	校验角色，保存消息，读取最近 12 条历史，装配授权上下文，调用模型或规则降级，保存回复。			
使用注意事项	匿名强制 public；禁止角色伪造和跨客人访问。			

7.3.13 5.3.13 hashPassword

函数名	hashPassword
文件名	server/src/db.js

功能概要	生成密码哈希			
参数	类型	变量名	I/O	说明
	password	string	IN	明文密码
返回值	string			
详细说明	生成 16 字节随机盐，使用 scrypt 派生 64 字节摘要。			
使用注意事项	明文密码不得写日志。			

7.3.14 5.3.14 log

函数名	log
文件名	server/src/db.js

功能概要	写入审计日志			
参数	类型	变量名	I/O	说明
	actorId	string	IN	操作人
	action	string	IN	动作
	targetType	string	IN	资源类型
	targetId	string	IN	资源编号
	detail	string	IN	脱敏说明
返回值	void			
详细说明	插入 audit_logs 并使用统一时间。			
使用注意事项	detail 不保存密钥和完整健康原文。			

7.4 5.4 关键数据结构说明

7.4.1 LoginDTO

字段	类型	说明
username	string	登录账号
password	string	登录密码，仅传输不存储
role	enum	guest/staff/dean

7.4.2 LoginVO

字段	类型	说明
token	string	访问令牌
user	PublicUserVO	安全用户信息

7.4.3 GuestProfileUpdateDTO

字段	类型	说明
phone	string	联系电话
emergencyContact	string	紧急联系人
mobility	string	行动能力

7.4.4 AdviceCreateDTO

字段	类型	说明
title	string	建议标题
content	string	建议正文
priority	enum	normal/important/urgent

7.4.5 AssistantChatDTO

字段	类型	说明
role	enum	public/guest/staff/dean
text	string	自然语言输入
sessionId	string?	会话编号
guestId	string?	工作人员场景下的客人编号

7.4.6 AssistantChatVO

字段	类型	说明
sessionId	string	会话编号
reply	string	助手回复
quickReplies	string[]	快捷问题
live	boolean	是否由真实模型生成
mode	string	真实模型服务或安全引导模式

7.4.7 GuestSummaryVO

字段	类型	说明
id/name/phone	string	用户基础信息
profile	GuestProfileVO	客人档案
health	HealthRecordVO[]	最近健康记录
advice	AdviceVO[]	有效医嘱

7.4.8 ErrorVO

字段	类型	说明
error	string	面向用户的错误信息

字段	类型	说明
requestId	string?	生产环境请求追踪号

8 6 非功能设计

8.1 6.1 安全与隐私

控制项	设计要求	验收方式
身份认证	强密钥、令牌过期、账号状态复查、登录限流	错误令牌和停用账号均返回 401
访问控制	服务端 RBAC 与资源级授权	越权读取返回 403/404，无数据泄露
密码保护	scrypt 加盐哈希，禁止明文日志	同一密码哈希不同，正确密码可验证
健康隐私	最小字段返回、传输加密、备份加密、留存策略	接口字段审查和访问日志检查
Agent 安全	角色绑定、上下文最小化、提示注入防护、人工确认	红队用例和医嘱发布链路检查
审计	关键操作记录 actor/action/target/time	抽查登录、查看、发布、评价日志

8.2 6.2 性能与可靠性

指标	目标
普通查询	生产环境 P95 不高于 500 ms
Agent 对话	设置 20–30 秒超时；超时后明确降级，不阻塞其他业务
并发	MVP 支持教学演示；生产按压测结果配置实例数和连接池
可用性	模型服务故障不影响登录、档案和医嘱等核心业务
数据完整性	外键、检查约束、事务和备份恢复共同保障
前端体验	请求期间显示加载状态，失败显示可理解且可恢复的提示

8.3 6.3 可维护性与可测试性

前端按公共页面、角色工作区和 AssistantWidget 划分组件；后端将数据库、认证、Agent 和路由

职责分离。接口字段、数据库迁移、环境变量和部署配置纳入版本控制。测试至少覆盖密码哈希、登录、RBAC、资源级授权、只读字段、医嘱发布、Agent 降级和模型异常。

8.4 6.4 部署与运维

环境	部署建议
开发	Vite 5180 + Express 3020 + SQLite，本地环境变量
测试	独立测试数据库、固定种子数据、模型 Stub、自动化接口测试
生产	Nginx HTTPS + Node 容器/PM2 + PostgreSQL + 密钥管理
监控	接口延迟、错误率、模型超时、数据库容量、审计异常
备份	数据库与配置分别备份；密钥不进入代码仓库和普通备份

9 7 当前完成度与后续计划

范围	当前完成情况	后续工作
页面与角色	公开首页、客人、工作人员、院长页面可运行	补充无障碍、移动端和完整空状态测试
账号与权限	登录、角色中间件、密码哈希已实现	增加登录限流、资源级负责关系、字段白名单整改
业务数据	SQLite 表、示例数据、健康记录和医嘱已实现	迁移 PostgreSQL、迁移脚本、备份恢复
Agent	悬浮助手、四角色路由、会话存储、兼容 API 和降级已实现	接入真实模型、内容安全、评测集、成本和延迟监控
审计管理	关键查看、发布和评价操作已留痕	脱敏、日志检索、留存策略和异常告警
测试	已有密码哈希单元测试	补充接口、权限、前端交互和端到端测试

本概要设计描述的是系统目标设计和当前实现基线。进入上线阶段前，必须关闭三项高优先级差距：建立工作人员与客人的资源级分配关系；收紧客人档案后端修改白名单；完成真实模型的安全评测与人工确认闭环。